

Security Fundamentals · Section 11

Security Roles and the Industry

By TOUCH DEN · November 11, 2026

Contents

What You Will Learn 1

Before You Start 1

1. The Shape of the Industry 1

2. Offensive Roles 2

3. Defensive Roles 2

4. Engineering and Architecture Roles 3

5. Governance, Risk, and Compliance Roles 3

6. How the Roles Work Together 4

7. Certifications at a Glance 5

Common Mistakes 5

Summary 6

Check Your Understanding 6

Practice 7

What You Will Learn

- *The overall shape of the security industry.*
- *Offensive roles: finding weaknesses by attacking (with permission).*
- *Defensive roles: watching, catching, and recovering from attacks.*
- *Engineering and architecture roles: building security in.*
- *Governance, risk, and compliance roles: the management side.*
- *How the roles work together, including the purple team.*
- *The main certifications, at a glance.*

Before You Start

Read lessons 1 to 10. You now understand what security work involves; this lesson maps that work onto real jobs, so you can see where you might fit, and how the courses ahead lead to each. No programming is needed.

---

1. The Shape of the Industry

Security is not one job; it is a whole industry of specialties, the same way "medicine" includes surgeons, nurses, radiologists, and administrators. People often sort security roles into a few broad families:

- ***Offensive** ("red"): find weaknesses by attacking systems, with permission.*
- ***Defensive** ("blue"): watch for, detect, and respond to attacks.*
- ***Engineering / architecture**: build and run systems so they are secure by design.*
- ***Governance, risk, and compliance (GRC)**: manage security as a business function, policy, risk, and audits.*

*These families map directly onto the paths in this program (Offensive, Defensive, Engineering, and the Specialized/GRC courses). Few people do all of them; most specialize, while keeping a working understanding of the others. Importantly, you do **not** have to be a brilliant hacker to have a security career. Many of the best-paid, most in-demand roles are defensive, engineering, or GRC, and value care, communication, and persistence as much as raw technical flair.*

A note for Cambodia and the region: demand for security people far outstrips supply almost everywhere, including locally and for remote work with foreign companies. This is a field where skills, a portfolio, and persistence open doors, which the Careers course covers in depth.

2. Offensive Roles

*Offensive security professionals attack systems, **with permission**, to find weaknesses before criminals do. They are sometimes called **ethical hackers**. The ethics rule from lesson 9 is their daily reality: everything is scoped and authorized.*

Common offensive roles:

- ***Penetration tester (pentester):** hired to test a specific system (a web app, a network) within a defined scope and time, then report the weaknesses and how to fix them.*
- ***Red teamer:** runs broader, goal-based, stealthy engagements that emulate a real attacker over weeks, to test not just systems but the organization's detection and response.*
- ***Vulnerability researcher / exploit developer:** digs deep into software to find new, unknown weaknesses (and often reports them responsibly).*
- ***Bug bounty hunter:** works independently, testing companies' systems through their published bounty programs, often for reward.*

*What the job is really like: a lot of methodical testing, research, and, crucially, **report writing**, explaining clearly what is wrong and how to fix it. The thrill of "breaking in" is a small part; the value is in the clear, actionable report. This family is the Offensive path: Web Application Security, Network Penetration Testing, Reverse Engineering, Exploitation, Red Teaming, and more.*

3. Defensive Roles

*Defensive security, the **blue team**, is the larger side of the industry by number of jobs, and where many people start. Defenders keep watch, catch attacks, and lead the recovery.*

Common defensive roles:

- ***SOC analyst:** works in a Security Operations Center, watching alerts and logs, triaging what is real, and raising incidents. A very common entry point into security.*
- ***Incident responder:** takes over when something serious happens, contains it, removes the attacker, and restores normal operations.*
- ***Digital forensics analyst:** investigates what happened, recovering and analyzing evidence from disks, memory, and networks.*
- ***Threat intelligence analyst:** studies attackers and their methods to help the organization anticipate and prioritize.*
- ***Threat hunter / detection engineer:** proactively searches for attackers that alerts missed, and writes better detections.*

Defensive work rewards curiosity, attention to detail, calmness under pressure, and good communication. It is less about dramatic hacking and more about noticing the one wrong thing among thousands of normal events. This family is the Defensive path: Security Operations, Incident Response, Digital Forensics, Malware Analysis, Threat Intelligence, and the Dark Web course.

4. Engineering and Architecture Roles

*While red and blue teams test and watch, **security engineers and architects build security in** from the start, which is cheaper and more effective than bolting it on later.*

Common roles:

- ***Security engineer:** builds and runs security tools and defenses, firewalls, monitoring, identity systems, and automates security tasks.*
- ***Application / product security engineer:** works with developers to build software securely, reviews code and designs, and runs security testing (the Secure Development course).*
- ***Cloud security engineer:** secures cloud environments (AWS, Azure, Google Cloud), a fast-growing, well-paid specialty.*
- ***Security architect:** designs how an organization's whole security fits together, choosing the controls and how systems connect safely.*

*These roles suit people who like **building** and often have a development or systems background. They are among the most in-demand and best-paid in the field. This family is the Engineering path: Secure Development, Cloud Security, Container Security, and Identity and Access Management.*

5. Governance, Risk, and Compliance Roles

*Not all security work is technical. **GRC** roles manage security as a business function, and are essential to any mature organization.*

Common roles:

- ***Security analyst / GRC analyst:** manages policies, risk assessments (lesson 3), and compliance with frameworks (lesson 10).*
- ***Auditor:** independently checks whether controls are in place and working.*
- ***Compliance manager:** ensures the organization meets its legal and contractual obligations (data protection, PCI DSS, ISO 27001).*

- ***CISO (Chief Information Security Officer):*** *the senior leader responsible for the whole security program, bridging security and business leadership.*

GRC roles reward people who are organized, clear communicators, and good with people and process. They are an excellent path for those who find the strategy, risk, and people side more interesting than deep technical work, and they often pay very well. This family is covered by the GRC course.

6. How the Roles Work Together

These are not rival camps; they form one system of defense, and the best security happens when they cooperate.

- ***Red and blue together make purple.*** *A* ***purple team*** *is not a permanent role but a way of working: red (attack) and blue (defend) collaborate directly, with red showing blue exactly how an attack works so blue can detect and block it. Instead of red "winning" by breaking in, both sides improve the organization's defenses together. This is the most productive use of offensive skills.*
- ***Engineers build what blue monitors and red tests.*** *A finding from a pentest becomes a fix by an engineer and a new detection by the SOC.*
- ***GRC sets the priorities*** *that direct everyone, based on risk, and reports the results to leadership.*

Understanding every role, even the ones you do not do, makes you better at your own, because you know how your work fits the whole. A pentester who understands the SOC writes more useful reports; an engineer who understands GRC builds what the business actually needs. This is why a program like this one teaches all the families before you specialize.

7. Certifications at a Glance

Security uses **certifications** heavily, as a common (if imperfect) way to signal knowledge to employers. You do not need any to start learning, and this program is not built around exams, but you should recognize the main names. The Careers course covers how and whether to pursue them.

Level	Example certifications	For
Entry / foundational	CompTIA Security+, CompTIA Network+	Proving broad fundamentals; many first jobs ask for Security+
Offensive	OSCP, CEH, and others	Pentesting and red-team roles; OSCP is hands-on and well-respected
Defensive / operations	Blue-team and SOC certifications	SOC, incident response, forensics
Management / GRC	CISSP, CISM, ISO 27001 Lead Auditor	Senior, architecture, and governance roles
Cloud	Cloud-provider security certifications	Cloud security roles

Two honest points. First, **certifications help you get interviews, but skills and a portfolio get you hired** (and keep you employed). Hands-on practice, labs, CTFs, and real projects, matters more than collecting letters. Second, do not feel you must chase certifications to belong in security; many excellent practitioners have few, and build their reputation on demonstrated work.

That demonstrated work is exactly what the rest of this program builds toward. You have now seen what security is, how attacks and defenses work, the rules that govern them, the frameworks that organize them, and the people who do the work. The final lesson turns all of this into a plan: your roadmap through the program, and your first steps into the field.

Common Mistakes

1. Thinking you must be an elite hacker to work in security. Most roles are defensive, engineering, or GRC, and value care, communication, and persistence as much as raw offensive skill.

2. Picturing the job as constant dramatic hacking. Offensive work is mostly methodical testing and report writing; defensive work is noticing the one wrong thing among thousands of normal events.

3. Seeing red and blue as enemies. *They are one system. Purple teaming, where they collaborate, produces the best defenses.*

4. Believing certifications equal skill. *Certifications open interviews; demonstrated skills and a portfolio get and keep the job.*

5. Overlooking GRC and engineering. *The non-"hacking" roles are among the most in-demand and best-paid, and suit many people better.*

6. Waiting to feel "qualified" before starting. *Demand far exceeds supply. Skills, a portfolio, and persistence open doors, especially for remote work.*

Summary

Family	Roles	Program path
Offensive (red)	Pentester, red teamer, researcher, bounty hunter	Offensive courses
Defensive (blue)	SOC analyst, incident responder, forensics, threat intel	Defensive courses
Engineering / architecture	Security / appsec / cloud engineer, architect	Engineering courses
GRC	GRC analyst, auditor, compliance manager, CISO	GRC course
Purple team	Red + blue collaborating to improve defenses	Red Teaming course
Certifications	Security+ (entry), OSCP (offensive), CISSP (management), cloud	Careers course

Check Your Understanding

1. Name the four broad families of security roles.
2. Why doesn't a security career require you to be a brilliant hacker?
3. What does a SOC analyst do, and why is it a common first job?
4. What is the difference between a penetration tester and a red teamer?
5. What is a purple team, and why is it productive?
6. What do engineering/architecture roles add that red and blue teams do not?
7. In one sentence, what is the honest relationship between certifications and getting hired?

Answers

1. *Offensive (red), defensive (blue), engineering/architecture, and governance-risk-compliance (GRC).*
2. *Because most roles are defensive, engineering, or GRC, which value attention to detail, communication, persistence, and process at least as much as offensive skill.*
3. *A SOC analyst watches alerts and logs, triages what's real, and raises incidents. It's a common entry point because it builds broad exposure and is in high demand.*
4. *A pentester tests a specific system within a defined scope and time and reports the weaknesses; a red teamer runs broader, stealthy, goal-based engagements that also test the organization's detection and response.*
5. *A way of working where red (attack) and blue (defend) collaborate directly, with red showing blue how an attack works so blue can detect and block it. It's productive because both sides improve the defenses together, rather than red just "winning".*
6. *They build security in from the start, the tools, systems, and designs, which is cheaper and more effective than bolting it on, and which red tests and blue monitors.*
7. *Certifications help you get interviews, but skills and a portfolio are what actually get and keep you hired.*

Practice

1. *Of the four role families, which **one** appeals to you most right now, and why? (There is no wrong answer; it may change.)*
2. *Pick one specific role from this lesson and write two or three sentences describing what a typical day might involve, in your own words.*
3. *Look back at the program's paths (see the repository's main page or lesson 1). Which **path** would move you toward the role you chose, and which course in it are you most curious about?*

A Worked Example

1. *Defensive appeals most: I like the idea of watching for and catching attackers, and it's a strong way to enter the field.*
2. *SOC analyst: they start a shift by reviewing overnight alerts, deciding which are false alarms and which are real, investigating the suspicious ones by checking logs, and escalating anything serious to an incident responder, all while keeping clear notes.*
3. *The Defensive path would move me toward it, and I'm most curious about the Security Operations course, with Digital Forensics a close second.*

Course mark icon from Material Symbols by Google, Apache License 2.0. NIST, CIS, ISO, OWASP, and MITRE ATT&CK are the trademarks of their respective owners, used here only to refer to their published work.